

Cybersecurity Daily Newsletter

Vol. 002 | 2026-06-11 07:00 WIB

Top 5 Highlights

- CISA directs federal agencies on prioritization of cyber vulnerabilities
- JDY botnet expands, enabling rapid exploitation of disclosed vulnerabilities
- Ransomware group The Gentlemen linked to Russian national
- ShinyHunters gang targets Oracle PeopleSoft servers in data theft attacks
- Scammers use short videos on social media to spread Vidar infostealer

Threat Intelligence (10)

01. Free Spotify Premium hacks on social media are spreading infostealers

Cybercriminals are turning TikTok and Instagram Reels into malware delivery platforms, using free software tutorials to spread infostealers.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/news/2026/06/free-spotify-premium-hacks-on-social-media-are-spreading-infostealers>

02. Chinese APTs have made identity part of the intrusion path

Don't merely identify the attacker - understand how they behave.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/perspective/chinese-apt-have-made-identity-part-of-the-intrusion-path>

03. China-Linked JDY Botnet Expands to 1,500+ Devices for Cyber Reconnaissance

Cybersecurity researchers have warned of a "resurgence and expansion" of JDY, a covert network associated with China-nexus state-sponsored threat actors. "The JDY botnet comprises over 1,500 SOHO [small office and home office] and IoT devices and operates as a centrally controlled, high-performance scanner used to discover, fingerprint, and continuously map...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/06/china-linked-jdy-botnet-expands-to-1500.html>

04. New SilabRAT Trojan Hijacks Sessions to Steal Crypto

MaaS trojan SilabRAT uses HVNC and browser cloning to hijack sessions and steal crypto

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/silabrat-trojan-session-hijacking/>

05. Cybersecurity Software Fails to Detect Fifth of Brower-Based Phishing Attacks

Menlo Security research warns that as enterprise applications become increasingly browser based, traditional cybersecurity tools leave them vulnerable to cyber threats

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.infosecurity-magazine.com/news/cybersecurity-fails-to-detect/>

06. China-linked JDY botnet expands targeting of U.S. military networks

The JDY botnet, a malware network previously associated with Chinese threat actors like Volt Typhoon, has significantly expanded its targeting scope and reconnaissance efforts. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/china-linked-jdy-botnet-expands-targeting-of-us-military-networks/>

07. The 5 Best Practices for Secure Identity Verification

Attackers are increasingly bypassing weak authentication through phishing, MFA fatigue, and service desk social engineering. Specops Software breaks down five best practices for stronger identity verification and access security. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources:

<https://www.bleepingcomputer.com/news/security/the-5-best-practices-for-secure-identity-verification/>

08. GitHub pulls pin on npm's auto-run scripts

Shai-Hulud worm exploited exactly this. Better late than never, says everyone except the malware authors

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.theregister.com/devops/2026/06/10/github-pulls-pin-on-npms-auto-run-scripts/5253453>

09. New Browser-in-the-Browser phishing uses fake login popups to steal Microsoft 365 credentials

A new Browser-in-the-Browser (BitB) phishing campaign is targeting Microsoft 365 users with fake login popups designed to closely mimic legitimate browser authentication windows, according to Palo Alto Networks Unit 42. The attack relies on a fake browser window embedded within a webpage. Victims who click a Microsoft sign-in button are presented with what...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources:

<https://www.helpnetsecurity.com/2026/06/10/browser-in-the-browser-phishing-microsoft-365-users/>

10. ISC Stormcast For Wednesday, June 10th, 2026

<https://isc.sans.edu/podcastdetail/9966>, (Wed, Jun 10th)

ISC Stormcast For Wednesday, June 10th, 2026 <https://isc.sans.edu/podcastdetail/9966>, (Wed, Jun 10th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33066>

Latest Vulnerabilities (10)

01. CISA directs federal agencies on prioritization of cyber vulnerabilities

The new directive, BOD 26-04, mandates that federal agencies focus on vulnerabilities that affect publicly exposed assets, can be fully automated by attackers, allow for complete system control, or show evidence of active exploitation.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/cisa-directs-federal-agencies-to-prioritize-cyber-vulnerabilities>

02. JDY botnet expands, enabling rapid exploitation of disclosed vulnerabilities

Initially flagged as part of the KV-botnet, JDY has evolved into an independent reconnaissance capability following the U.S. government's takedown of KV in early 2024.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/jdy-botnet-expands-enabling-rapid-exploitation-of-disclosed-vulnerabilities>

03. ShinyHunters gang targets Oracle PeopleSoft servers in data theft attacks

The ShinyHunters gang is exploiting a combination of old and zero-day vulnerabilities, referred to as a "gadget chain," to target both cloud and on-premises Oracle PeopleSoft instances.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/brief/shinyhunters-gang-targets-oracle-peoplesoft-servers-in-data-theft-attacks>

04. Path traversal flaw in AI dev platform Langflow exploited in attacks

Attackers are actively exploiting CVE-2026-5027, a high-severity path traversal vulnerability in the AI development platform Langflow, to write arbitrary files on exposed servers. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/path-traversal-flaw-in-ai-dev-platform-langflow-exploited-in-attacks/>

05. CISA Rewrites Federal Patching Requirements for AI Threat Era

The new directive gives federal agencies three days to fix the most dangerous flaws, while less severe issues can be deferred.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.darkreading.com/cyber-risk/cisa-rewrites-federal-patching-requirements-ai-threat-era>

06. The 'Miasma' worm source code briefly leaked on GitHub

The Miasma credential-stealing attack framework, which has recently targeted open-source ecosystems through supply-chain attacks, was briefly open-sourced on GitHub. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/the-miasma-worm-source-code-briefly-leaked-on-github/>

07. CISA tells agencies to patch smarter, not harder - foreshadowing broader industry practice

Security teams' patching practices have come under intense pressure over the past year, as active exploitation is up, time-to-exploit windows are accelerating, and vulnerabilities have become attackers' top initial access vector of choice. Last year, organizations fully remediated only 26% of the vulnerabilities that attackers were actively exploiting in th...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4183750/cisa-tells-agencies-to-patch-smarter-not-harder-for-eshadowing-broader-industry-practice.html>

08. Ivanti patches critical Sentry flaws that lead to full device takeover

IT software provider Ivanti fixed two vulnerabilities in Ivanti Sentry, a secure mobile gateway appliance formerly called MobileIron Sentry. The flaws could allow unauthenticated remote attackers to gain complete control of deployments. One of the vulnerabilities, CVE-2026-10523, credited to researcher Bryan Lam, allows attackers to bypass authentication an...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4183735/ivanti-patches-critical-sentry-flaws-that-lead-to-full-device-takeover.html>

09. How Federal Agencies Can Activate a Risk Operations Center (ROC) to Meet CISA BOD 26-04

Executive Summary Recognizing the ability of Frontier AI models to discover and exploit vulnerabilities at unprecedented speed and scale, CISA's Binding Operational Directive (BOD) 26-04 marks a significant shift in federal vulnerability management. Rather than prioritizing remediation based on patch availability, the directive requires agencies to focus on...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://blog.qualys.com/qualys-insights/2026/06/10/how-federal-agencies-can-activate-a-risk-operations-center-roc-to-meet-cisa-bod-26-04>

10. Angry bug hunter with Microsoft beef drops new Windows 0-day

Revenge is a dish best served code

Why it matters: Publicly discussed 0-days often see rapid weaponization, increasing the risk of opportunistic attacks at scale.

Recommendation: Apply vendor guidance immediately, reduce attack surface, and monitor for IoCs/exploitation telemetry until patches are fully deployed.

Sources: <https://www.theregister.com/security/2026/06/10/nightmare-eclipse-publishes-new-windows-defender-zero-day/5253725>

Data Breach & Cybercrime (10)

01. Ransomware group The Gentlemen linked to Russian national

The Gentlemen ransomware group, as analyzed by Check Point Software, operates on a ransomware-as-a-service model, attracting skilled hackers with an unusually high 90/10 affiliate revenue split.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.scworld.com/brief/ransomware-group-the-gentlemen-linked-to-russian-national>

02. Scammers use short videos on social media to spread Vidar infostealer

This new attack method, reported by ReversingLabs, involves creating seemingly helpful tutorial videos that promise free access to premium applications such as Spotify Premium or Microsoft Word.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.scworld.com/brief/scammers-use-short-videos-on-social-media-to-spread-vidar-infostealer>

03. Bug Bounty Research Triggers ServiceNow Security Alert

Bug bounty research inadvertently led organizations to believe they were being breached through their ServiceNow instances.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/vulnerabilities-threats/bug-bounty-research-triggers-servicenow-security-alert>

04. Oracle PeopleSoft servers hacked in ShinyHunters data theft attacks

Oracle PeopleSoft servers are being targeted in ongoing data theft attacks by the ShinyHunters extortion gang, which claims to have stolen data from over 100 organizations. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/oracle-peoplesoft-servers-hacked-in-shinyhunters-data-theft-attacks/>

05. Who Runs the Ransomware Group 'The Gentlemen?'

A cybercrime group known as The Gentlemen has emerged as the second most active ransomware gang by victim count, rapidly attracting a talented pool of hackers through an aggressive recruitment strategy that promises affiliates 90 percent of any ransom paid by victims. This post examines clues pointing to a real life identity for the administrator of The Gen...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://krebsonsecurity.com/2026/06/who-runs-the-ransomware-group-the-gentlemen/>

06. Infostealers Turn Millions of Devices Into Credential Theft Machines

As attackers increasingly favor stolen credentials over exploits, infostealers have become a primary source of access for ransomware and other cybercrime operations. The post Infostealers Turn Millions of Devices Into Credential Theft Machines appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources:

<https://www.securityweek.com/infostealers-turn-millions-of-devices-into-credential-theft-machines/>

07. 88% of people struggle to tell what's real online

As AI-generated scams, deepfakes, and impersonation spread, a new Malwarebytes report finds people increasingly unsure what to trust online.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/ai/2026/06/88-of-people-struggle-to-tell-whats-real-online>

08. [+24h Old] Scammers love Meta, according to Lloyds Bank

Facebook, Instagram, and WhatsApp account for more than two thirds of fraud reports made by Lloyds customers.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.malwarebytes.com/blog/scams/2026/06/scammers-love-meta-according-to-lloyds-bank>

09. [+24h Old] France probes compromise of gov messaging platform after account hijack

Authorities say the breach only exposed public chat rooms, but alleged attacker claims to have accessed far more data

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/security/2026/06/09/france-probes-compromise-of-gov-messaging-platform-after-account-hijack/5252717>

10. [+24h Old] Qilin NHS breach tally grows as Essex trust confirms stolen records

Two years on from ransomware attack, hospitals are still trying to identify and warn patients

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.theregister.com/cyber-crime/2026/06/09/qilin-nhs-breach-tally-grows-as-essex-trust-confirms-stolen-records/5252663>